CASE STUDY

The XZ Utils Backdoor: A 2024 Supply-Chain Case Study

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

In March 2024 a backdoor was found in XZ Utils, the compression project whose `liblzma` library ships on almost every Linux system. An attacker operating as a trusted maintainer spent more than two years earning commit and release authority, then hid a backdoor in the release tarballs of versions 5.6.0 and 5.6.1. On the distributions that link `liblzma` into OpenSSH through systemd, the backdoor hooked the SSH authentication path so that anyone holding the attacker's private key could run commands as root before authenticating. It was caught by one engineer who noticed that SSH logins had become about half a second slower, not by any systematic control. The lesson is that source-level review is not enough when the malicious code is injected at build time, and that critical infrastructure maintained by a single volunteer is a supply-chain single point of failure.

> Evidence grade: **Confirmed** (a tracked CVE, extensive independent analysis, and a reconstructed multi-year campaign).

Key facts at a glance

Field	Value
Identifier	CVE-2024-3094, CVSS 10.0
Component	XZ Utils `liblzma` , backdoored in release tarballs 5.6.0 and 5.6.1
Nature	Maintainer compromise and build-time injection, not a code-level vulnerability
Target	sshd on x86-64 glibc distributions that link `libsystemd` (and thus `liblzma`)

Field	Value
Effect	Pre-authentication remote code execution as root for a client holding the attacker's key
Exposure window	Backdoored tarballs shipped 24 February to 9 March 2024
Who shipped it	Rolling and pre-release channels (Debian sid/testing, Fedora Rawhide/41 beta, Arch, openSUSE Tumbleweed, Kali, Homebrew); stable LTS releases did not
Discovery	Andres Freund traced a 500 ms SSH login slowdown, disclosed 29 March 2024
Known in-the-wild use	None publicly evidenced before discovery

Key findings

- **The compromise was the maintainer, not a vulnerability.** An identity operating as "Jia Tan" (JiaT75) built credibility over about two to two and a half years, became a co-maintainer and release manager, and used the trust to ship the backdoor. Sockpuppet accounts pressured the original, overworked sole maintainer to cede control.
- **The backdoor lived in the tarball, not the git source.** The malicious payload was a prebuilt object concealed in files disguised as compression test data, assembled into `liblzma` by obfuscated build scripts. A reviewer reading the GitHub source would not have seen it; it appeared only in the released tarball.
- **It targeted sshd through a distro-specific link.** OpenSSH does not use `liblzma` . Several distributions patch sshd to depend on `libsystemd` , which pulls in `liblzma` . The backdoor used a glibc IFUNC resolver to hook the signature-verification path used during SSH login on x86-64 glibc systems, giving pre-authentication remote code execution to a client that presents a payload signed with the attacker's key.
- **Only bleeding-edge systems shipped it.** The backdoored 5.6.0 and 5.6.1 reached rolling and pre-release distributions (Debian unstable and testing, Fedora Rawhide and 41 beta, Arch, openSUSE Tumbleweed, Kali) and Homebrew. Stable long-term releases, including Debian stable, Ubuntu LTS, and RHEL, had not adopted them.
- **Discovery was luck, not control.** Andres Freund, a Microsoft engineer, investigated a performance regression in Debian unstable, saw SSH logins taking about 500 ms longer than expected and Valgrind errors pointing at `liblzma` , and traced it to the backdoor. He reported it on 29 March 2024.

Top recommendations

1. Keep a software bill of materials, and alert on `xz` / `liblzma` 5.6.0 and 5.6.1 and on any package pulled from a rolling or pre-release channel into production.
2. Verify builds from source you can reproduce, not only from release tarballs; prefer reproducible builds and signed provenance (SLSA).
3. Treat maintainer and account changes on critical dependencies as security events, and fund or mirror the projects you depend on so a single burned-out volunteer is not your only line of defense.

4 Detect by behavior, not just by version: unexplained latency or resource use in an authentication path is worth investigating.

Scope and method

This study covers the XZ Utils backdoor tracked as CVE-2024-3094, from primary disclosure and independent analysis. Each claim carries one of three evidence grades.

Grade	Meaning
Confirmed	An observed, attributed event with technical detail from the disclosure, a distribution, or a government agency
Reported	A single account, not independently corroborated
Demonstrated	A research reconstruction with no separate in-the-wild use

What happened

XZ Utils provides the `xz` command and `liblzma`, a compression library linked by a large number of programs. Between 24 February and 9 March 2024, the project's release manager shipped tarballs for versions 5.6.0 and 5.6.1 that contained a backdoor (**Confirmed**: CVE-2024-3094, CVSS 10.0).

The payload was not in the project's git source. It was a prebuilt object file hidden inside files that looked like corrupt compression test inputs, and the project's build scripts (an obfuscated step in the release tarball's `configure` machinery) extracted and linked it during compilation (**Confirmed**: independent analysis). Because the malicious code entered only at build time and only in the tarball, the usual defence of reading the source on GitHub would not have revealed it.

On x86-64 Linux systems using glibc, the compromised `liblzma` used an IFUNC resolver (a glibc feature that lets a library pick a function implementation at load time) to hook into the code path that verifies signatures during an SSH login (**Confirmed**: independent analysis). OpenSSH itself does not depend on `liblzma`; the link exists only because several distributions patch sshd to depend on `libsystemd`, which depends on `liblzma`. A remote client that presented a command payload signed with the attacker's private key would have the backdoored sshd run it as root, before authentication. No separate credential was needed.

The social-engineering campaign

The technical backdoor rested on a human compromise built over roughly two to two and a half years (**Confirmed**: reconstructed commit and mailing-list history). The "Jia Tan" identity began contributing to XZ Utils, built a record of legitimate work, and became a co-maintainer and then a release manager. During the same period, a set of apparently coordinated accounts pressured the project's long-time sole maintainer, who had spoken publicly about burnout, to accept help and hand over authority. By the time the backdoor shipped, the attacker controlled the release process. This is why the incident is better read as a maintainer compromise than as a software vulnerability: the trust model of open-source distribution was the target.

How it was found

Andres Freund, a Microsoft engineer and PostgreSQL contributor, was investigating why SSH logins on a Debian unstable system were slower than expected, about 500 ms of extra latency, along with Valgrind errors (**Confirmed**: Freund's disclosure to the oss-security list). He traced the cost to `liblzma` , analysed the library, and found the backdoor. He disclosed it on 29 March 2024. The response was immediate: distributions pulled the affected versions, advised downgrading to the 5.4 series, and CISA issued an alert the same day. There is no public evidence that the backdoor was used against a production target before discovery (**Reported**).

Who was affected

The exposure was limited by timing. The backdoored 5.6.0 and 5.6.1 had reached rolling and pre-release channels but not the stable releases most production fleets run.

Affected	Not affected
Debian unstable (sid) and testing	Debian stable
Fedora Rawhide and Fedora 41 beta	Fedora stable releases on older xz
Arch Linux (xz 5.6.0-1 and 5.6.1-1)	Ubuntu LTS
openSUSE Tumbleweed, Kali	RHEL and derivatives on the 5.4 series
Homebrew formulae on 5.6.1	Any system still on xz 5.4.x

Timeline

Date (2024)	Event
~2021 to 2024	The "Jia Tan" identity builds trust and gains co-maintainer then release authority
24 February	XZ Utils 5.6.0 tarball, carrying the backdoor, released
9 March	5.6.1 tarball released
29 March	Andres Freund discloses the backdoor to oss-security; distributions pull the versions; CISA issues an alert
Following days	Distributions ship reverted or patched packages and advise downgrading to the 5.4 series

Detection

Detection has two layers, because a version check alone can miss a transitively pulled copy (**Confirmed** as general guidance):

- **Version and inventory.** Check the installed `xz` / `liblzma` version on every host and image (`xz --version` , and the per-platform package queries below), and query your SBOMs for 5.6.0 and 5.6.1 anywhere in the estate, including base images and vendored builds.
- **Known-signature checks.** Community detection scripts (including the one CISA referenced) inspect the loaded `liblzma` for the backdoor's tell-tale function signatures and IFUNC hook rather than trusting the version string; run one against affected hosts to confirm a replaced library is genuinely clean.
- **Behavioral.** The backdoor was found by latency: unexplained extra time or resource use in the SSH authentication path is the behavioral signal, and it is worth alerting on for any auth-path regression, not just this bug.

As an interim mitigation before a host can be remediated, reduce sshd exposure: restrict SSH to management networks or a VPN, limit source addresses at the firewall, and on affected hosts consider stopping sshd or temporarily removing the `liblzma` link until the package is replaced. These reduce reachability; they are not a fix.

Remediation by platform

The fix is to get off 5.6.0 and 5.6.1 and back to a known-good build (the 5.4 series, or a distro package explicitly marked as reverted or patched). After replacing the library, restart sshd so the clean `liblzma` is actually loaded.

Platform	How to check and remediate
Debian / Ubuntu	`dpkg-query -W xz-utils liblzma5` and `apt-cache policy liblzma5` ; `sudo apt-get update && sudo apt-get install --only-upgrade xz-utils liblzma5` to pull the reverted package; on unstable, pin back to the 5.4 series
RHEL / Fedora / Rocky / Alma	`rpm -q xz xz-libs` ; `sudo dnf downgrade xz xz-libs` to the 5.4 series where 5.6 was installed (mainly Rawhide and the Fedora 41 beta)
Arch	`pacman -Q xz` ; `sudo pacman -Syu` to 5.6.1-2 or later, which removed the backdoor
openSUSE	`zypper info xz liblzma5` ; `sudo zypper up` to the patched package
Alpine	not affected (musl, not glibc, and did not ship 5.6.x in a vulnerable path); confirm with `apk info -v xz`
macOS (Homebrew)	`brew list --versions xz` ; `brew update && brew upgrade xz` off 5.6.1
Containers and CI	rebuild every image from a base that no longer carries 5.6.0 or 5.6.1, pin by digest, and redeploy; scan images and SBOMs for the two versions

Platform	How to check and remediate
Source and vendored builds	if you build `xz` / `liblzma` from a tarball, rebuild from a verified 5.4.x source or a reproducible 5.6.x the project re-released, not the 5.6.0 or 5.6.1 tarballs

A version check alone is not the whole answer: confirm that nothing in the estate pulled 5.6.0 or 5.6.1 transitively, and that sshd on affected hosts was restarted after the library was replaced.

The lessons

- **Build-time injection beats source review.** Pin and verify what you build and ship, use reproducible builds, and generate provenance so the artifact can be tied to reviewed source. See Supply Chain Security Reference.
- **Maintainer trust is an attack surface.** Sudden changes in who maintains or releases a critical dependency deserve the same scrutiny as a code change.
- **Single-maintainer dependencies are concentration risk.** The projects a fleet depends on most are often the least resourced; fund, mirror, or contribute to them.
- **Behavioral signals matter.** The backdoor was found because one engineer treated unexplained latency in an auth path as a problem worth chasing.

Sources

- The original disclosure by Andres Freund to the oss-security (Openwall) mailing list, 29 March 2024.
- CVE-2024-3094 (NVD) and the CISA alert of 29 March 2024.
- Red Hat, Debian, Arch, Fedora, and openSUSE security advisories.
- The OpenSSF advisory and independent technical analyses of the payload and build chain.

Related references

- Supply Chain Security Reference (SBOMs, SLSA, signing, and the Notable Supply Chain Incidents list)
- Notable Incidents
- Package Managers Reference
- Linux Hardening Reference